

Web Security Assessment

Metasploitable2 Laboratory

Target: 192.168.196.129

Environment: Local VMware Lab

Prepared as a cybersecurity portfolio project

1. Executive Summary

A web security assessment was performed against a deliberately vulnerable Metasploitable2 virtual machine in a controlled local VMware laboratory. The assessment focused on HTTP service identification, web technology enumeration, directory discovery, HTTP method analysis, WebDAV configuration, and controlled file upload testing.

The assessment identified an outdated Apache and PHP stack, an exposed WebDAV endpoint, multiple enabled WebDAV methods, successful file uploads, and a successful PHP execution result reported by DAVTest.

2. Scope

Item	Value
Target	Metasploitable2
IP Address	192.168.196.129
Environment	Local VMware laboratory
Assessment Type	Web security assessment

3. Methodology

The testing followed a basic web enumeration workflow: identify the web service, fingerprint the technologies, enumerate accessible directories, inspect HTTP/WebDAV capabilities, and perform controlled WebDAV file upload testing using DAVTest.

4. Tools Used

- cURL
- WhatWeb
- Gobuster
- DAVTest

5. Web Server Enumeration

The HTTP service returned HTTP 200 OK. The response identified Apache 2.2.8 on Ubuntu and PHP 5.2.4-2ubuntu5.10. The server also exposed WebDAV/2.

Evidence command:

```
curl -I http://192.168.196.129
```

Observed server information: Apache/2.2.8 (Ubuntu) DAV/2 and X-Powered-By: PHP/5.2.4-2ubuntu5.10.

6. Technology Identification

WhatWeb identified Apache 2.2.8, Ubuntu Linux, PHP 5.2.4-2ubuntu5.10, WebDAV/2, and the page title 'Metasploitable2 - Linux'.

Command:

```
whatweb http://192.168.196.129
```

7. Directory Enumeration

Gobuster discovered several accessible or restricted paths, including /dav/, /phpMyAdmin/, /twiki/, /test/, phpinfo.php, phpinfo, index, and index.php. The /dav/ directory returned a redirect and was subsequently tested for WebDAV functionality.

Command:

```
gobuster dir -u http://192.168.196.129 -w /usr/share/wordlists/dirb/common.txt
```

8. WebDAV Assessment

An HTTP OPTIONS request against /dav/ confirmed WebDAV support. The response included DAV: 1,2 and MS-Author-Via: DAV. The Allow header listed several methods, including PUT-related WebDAV operations such as PROPPATCH, COPY, MOVE, LOCK, and UNLOCK, along with DELETE and other HTTP methods.

Command:

```
curl -X OPTIONS -i http://192.168.196.129/dav/
```

The observed Allow header included: OPTIONS, GET, HEAD, POST, DELETE, TRACE, PROPFIND, PROPPATCH, COPY, MOVE, LOCK, UNLOCK.

9. WebDAV File Upload Testing

DAVTest successfully created a temporary test directory and uploaded multiple file types using PUT. The tested extensions included ASPX, SHTML, PL, PHP, JSP, ASP, CGI, TXT, JHTML, HTML, and CFM.

Command:

```
davtest -url http://192.168.196.129/dav/
```

10. PHP Execution Result

DAVTest reported a successful execution result for the uploaded PHP test file. This indicates that the WebDAV location permitted upload of a PHP file and that the test file was processed as executable content according to DAVTest.

11. Findings

ID	Finding	Risk
F-01	Outdated Apache and PHP versions detected	High
F-02	WebDAV enabled on /dav/	Medium
F-03	WebDAV permits file uploads	High
F-04	Uploaded PHP test file reported executable	Critical

12. Impact

An exposed and writable WebDAV directory increases the attack surface. If an attacker can upload server-side executable content and the server executes it, the weakness may lead to unauthorized code execution within the privileges of the web service. The assessment was limited to the controlled laboratory environment.

13. Recommendations

- Disable WebDAV if the application does not require it.
- Restrict WebDAV access to authenticated and authorized users.
- Disable unnecessary write methods and file upload capabilities.
- Prevent execution of uploaded server-side scripts.
- Upgrade outdated Apache and PHP components to supported versions.
- Monitor WebDAV activity and uploaded files.
- Restrict access to management and testing applications such as phpMyAdmin and phpinfo.

14. Evidence

Screenshots captured during testing should be stored in the project's screenshots directory. Recommended evidence includes the HTTP header output, WhatWeb result, Gobuster result, WebDAV OPTIONS response, and DAVTest result.

15. Conclusion

The assessment demonstrated several web security weaknesses in the Metasploitable2 laboratory target. The most significant observation was the combination of an enabled WebDAV endpoint, successful file uploads, and a PHP execution result reported by DAVTest. These results provide practical evidence for the web security assessment and form the basis for remediation recommendations.